

HypoRAG: Supplemental Methods and Reproduction Notes

This document records the definitions and implementation details behind the top-1 retrieval comparison and the released pipeline code. The paired benchmark data and generated knowledge base are distributed separately.

A. Top-1 retrieval study

Fifty vulnerable functions were sampled from the PrimeVul-v0.1 test split with a fixed seed. The candidate corpus contained 3,611 eligible vulnerable functions from the training split. Random selection, BM25 over complete function code, dense code retrieval, and dense retrieval over generated functional summaries each returned one historical case per function. Hypothesis-guided retrieval returned one case for each of 141 hypotheses from the same 50 functions. Cases sharing a project or CVE with the query, or with token Jaccard at least 0.80, were excluded. All 341 pairs are in retrieval_diagnostic/.

Retriever	N	Token Sim.	Call Overlap	Mech. Match
Random	50	0.0436	0.0000	4/50 (8%)
BM25	50	0.0899	0.0494	10/50 (20%)
Dense-Code	50	0.0887	0.0516	6/50 (12%)
Dense-LLM	50	0.0846	0.0399	10/50 (20%)
Hypothesis-Guided	141	0.0621	0.0235	114/141 (80.9%)

Table A1. Filtered top-1 retrieval results. The function-level methods share 50 targets; Hypothesis-Guided uses 141 hypotheses from those targets. The supplied manuscript prints 0.0400 for Random Token Sim.; the released rows recompute to 0.0436.

B. Surface similarity

Token similarity is the archived set Jaccard score on lexical tokens: $|T_q \cap T_c| / |T_q \cup T_c|$. Call overlap is asymmetric: $|C_q \cap C_c| / |C_q|$, using distinct query-side and case-side callee names. The released per-pair scores allow independent recomputation of the means in Table A1.

C. Mechanism judgment

The audit has three levels: 0 for unrelated, 1 for a transferable verification principle, and 2 for the same decisive failed condition. Table A1 counts levels 1 and 2 as mechanism matches. Shared CWE alone does not establish a match. The audit packets include descriptions, repair diffs, and a rationale per pair.

The released file records the final human-adjudicated three-level label and rationale for each of the 200 function-level and 141 hypothesis-level pairs. Two annotators independently applied the protocol, and a third adjudicated disagreements.

D. Structured knowledge and online inference

For each training repair pair, the pipeline extracts a repair signature, then independently constructs retrieval fields and verification guidance. The retrieval fields describe mechanism, repair, and decisive evidence. They are indexed as separate dense views. The guidance fields are case explanation, vulnerable pattern, repaired pattern, and verification guidance.

At test time, a single vulnerable or safe function is processed without its paired counterpart. The detector proposes localized hypotheses, retrieves candidates from three views within an assigned family, deduplicates by knowledge ID, reranks the union, and passes the selected guidance fields to point verification. An option in the formal runner aggregates supported point judgments using a deterministic Boolean OR.

E. Reranker and evaluation bookkeeping

Teacher utility labels take values 0, 1, or 2. Canonical pairwise training examples are formed only within complete query groups and only between candidates with unequal utility labels. The training objective weights pairwise logistic loss by the label gap. Ranking evaluation can report micro preference accuracy, macro per-query preference accuracy, MRR, NDCG, and recall on the same test groups before and after fine-tuning.

Pair outcomes are exhaustive for valid vulnerability/repair pairs: Both-R (vulnerable side flagged, repaired side safe), Both-W (reverse), Both-s (both safe), and Both-v (both flagged). The four counts sum to the number of valid pairs. Incomplete or unparseable records are reported separately and are not silently placed into any outcome class.

F. Reproducibility boundary

The release includes all 341 query/case pairs, final audit labels, rationales, and metric code. A reader can recompute Table A1 offline. Re-running dense retrieval or generation from scratch requires the original benchmark, chosen local encoder, and configured inference endpoint. The release intentionally omits private credentials, model weights, and the generated knowledge base.

G. Artifact field guide

`retrieval_pairs.jsonl` stores method, query and candidate IDs, ranking score, surface scores, exclusion flags, and both vulnerable function bodies. `mechanism_audit.jsonl` adds the hypothesis where applicable, descriptions, repair diffs, three-level label, and rationale for all 341 pairs.

The semantic summary file contains sanitized functional summaries for the training candidates and selected test queries. It omits model identifier, raw response, and billing fields. The manifest fixes the 50 query IDs and exclusion settings; `candidate_ids.json` fixes the 3,611-item candidate corpus.

H. Failure and coverage reporting

The formal runner writes append-only stage outputs with input hashes and success or failure status. Resumption skips successful records and retries only selected failures. A valid end-to-end pair requires successful processing of both function sides; reported confusion counts and paired outcomes use the same valid-pair denominator. Excluded inputs and parsing failures remain explicit in the stage reports.